

Phishing Detection & Awareness Report

Phishing Email Detection & Awareness System

Cyber Security Task 2 — Future Interns

Prepared by: Kabiraj Chapagain

Program: Cyber Security Internship

Table of Content

1. Executive Summary	3
2. Objective & Scope.....	3
3. Methodology & Tools Used	3
4. Risk Classification Framework	4
5. Sample Analysis.....	4
5.1 Sample 1 — Account Verification Email	4
5.2 Sample 2 — Finance/Invoice Email.....	5
5.3 Sample 3 — IT Helpdesk Storage Notice	5
5.4 Sample 4 — Legitimate Security Alert (for contrast).....	6
6. Evidence & Tool Findings.....	6
6.1 Sample 1 — Account Verification	6
6.2 Sample 2 — Finance/Invoice	9
6.3 Sample 3 — IT Helpdesk Notice.....	10
6.4 Sample 4 — Legitimate Security Alert (baseline).....	11
7. Common Phishing Indicators Checklist.....	13
8. Prevention Guidelines	13
Do's	13
Don'ts.....	14
9. Conclusion	14

1. Executive Summary

This report analyzes four representative email samples to demonstrate how phishing attempts are identified, classified, and explained to non-technical staff. The goal is to show a practical, repeatable analysis process, not to catalogue every possible attack and to translate the findings into guidance employees can follow.

Two samples are classified as Phishing, one as Suspicious, and one as Safe. The Suspicious case is included deliberately: it shows that passing authentication checks does not automatically mean an email is safe if the sending domain itself is impersonating a trusted brand.

2. Objective & Scope

- Analyze sample phishing emails using header and content inspection.
- Identify common phishing indicators (sender, links, language, authentication results).
- Classify each email as Safe, Suspicious, or Phishing.
- Translate technical findings into plain-language guidance for employees.
- Produce prevention guidelines suitable for internal security awareness training.

3. Methodology & Tools Used

Analysis approach for each sample:

- Inspect the From, Reply-To, and Return-Path headers for mismatches.
- Check SPF, DKIM, and DMARC authentication results.
- Inspect linked URLs for lookalike or unrelated domains, without visiting them directly.
- Assess the language for urgency, threats, or fear-based pressure.
- Check for generic greetings versus personalized, expected communication.

Tools used: MXToolbox ,SuperTool (HTTP/HTTPS lookup, certificate lookup, WHOIS), MXToolbox Email Header Analyzer, and Google search for supporting context. Links were only checked through these lookup tools; they were never opened in a browser.

Note on the samples: the four emails are constructed, illustrative examples written for this exercise, modelled on common real-world patterns. Their Authentication-Results, Return-Path, From, and Reply-To values were written into each sample's raw header and then independently run through MXToolbox's Email Header Analyzer, which parsed them, traced the relay, and checked the relay IP against blacklists (see section 6). Where an example domain turned out to be registered to a real party, it is reported neutrally and no claim is made about its owner.

4. Risk Classification Framework

Indicator	Observed	Why It Matters
Safe	Sender domain matches the organization; SPF/DKIM/DMARC pass; no urgency or credential requests.	Consistent with expected, legitimate communication.
Suspicious	Some red flags present (mismatched links, unexpected request) but authentication may pass or sender may look legitimate at a glance.	Warrants a second look or a report to IT before acting.
Phishing	Clear indicators: spoofed/lookalike domain, failed authentication, urgent threats, credential or payment requests.	Should be reported and deleted; do not click, reply, or download.

5. Sample Analysis

5.1 Sample 1 — Account Verification Email

Subject: “Urgent: Your Account Will Be Locked” — Sender: support@secure-account-verify.com

Indicator	Observed	Why It Matters
Sender domain	secure-account-verify.com — not a real, recognizable company domain.	Attackers register lookalike domains to appear official.
Reply-To mismatch	Replies route to a different domain (verify-mail-support.ru).	Legitimate companies rarely reply from a different, unrelated domain.
Authentication	SPF fail, DKIM none, DMARC fail.	The email cannot be verified as coming from a legitimate source.
Urgency language	“24 hours” deadline and account lock threat.	Fear and urgency are designed to bypass careful thinking.
Generic greeting	“Dear User” instead of a real name.	Legitimate account-specific notices usually address the user by name.

Risk Classification: Phishing

Plain-language explanation: This email pretends to be from a security team to scare the reader into clicking a link and entering login details on a fake page. The domain, reply address, and failed authentication all confirm it is not genuine.

5.2 Sample 2 — Finance/Invoice Email

Subject: "Outstanding Invoice #4471 - Payment Required Today" — Sender: billing@invoice-payment-portal.com

Indicator	Observed	Why It Matters
Sender domain	invoice-payment-portal.com — generic, unrelated to any known vendor.	Finance-themed phishing often invents a plausible-sounding billing domain.
Authentication	SPF softfail, DKIM none, DMARC fail.	Weak/failed authentication indicates the domain is not properly configured or is spoofed.
Urgency + financial pressure	"Service suspension effective today."	Targets employees who handle payments, pressuring quick action.
Vague target line	"If you have already updated your banking details..."	A common trick to make the reader assume a prior legitimate interaction exists.

Risk Classification: **Phishing**

Plain-language explanation: This is a Business Email Compromise (BEC) style attempt aimed at the finance team, using invoice pressure to get someone to click a link or update payment details. No real vendor relationship is confirmed anywhere in the message.

5.3 Sample 3 — IT Helpdesk Storage Notice

Subject: "Mailbox Storage Almost Full - Action Needed" — Sender: it-notify@company-helpdesk.com

Indicator	Observed	Why It Matters
Authentication	SPF pass, DKIM pass, DMARC pass for company-helpdesk.com.	Passing authentication only proves the email came from that domain — not that the domain is genuinely your employer's IT department.
Link domain confusion	Link points to company-helpdesk.com.mailbox-tools.net, where the real domain is mailbox-tools.net.	Attackers put a trusted-looking name in front of an unrelated domain to fool a quick glance.
Plausible, low-pressure content	No threats, believable IT topic.	Low-pressure pretexts are used specifically to avoid raising suspicion.

Risk Classification: **Suspicious**

Plain-language explanation: Nothing here is as obviously fake as Samples 1 and 2, which is exactly what makes it worth flagging. The link's real destination is a different domain than it appears to be. Employees should hover over links (without clicking) and verify the true destination domain before acting, or forward it to IT to confirm.

5.4 Sample 4 — Legitimate Security Alert (for contrast)

Subject: “Security alert: New sign-in from Windows device” — Sender: no-reply@accounts.google.com

Indicator	Observed	Why It Matters
Sender domain	accounts.google.com — matches the real service exactly.	No lookalike substitution or added words.
Authentication	SPF pass, DKIM pass (header.d=google.com), DMARC pass.	Full authentication alignment with the claimed sender.
Link destination	myaccount.google.com — the real account management domain.	Matches the sender's actual domain.
Tone	Informational, no threats, explicitly states password will never be requested by email.	Legitimate security messaging avoids pressure tactics.

Risk Classification: **Safe**

Plain-language explanation: Every signal is consistent — sender, authentication, and link destination all match the real service, and the message does not ask for credentials. This is included to show what a genuine notification looks like next to the phishing samples above.

6. Evidence & Tool Findings

The screenshots below were captured during the analysis (lookups run on 27 September 2026). Each is followed by a plain-language explanation of what it shows and how it supports the classification.

6.1 Sample 1 — Account Verification

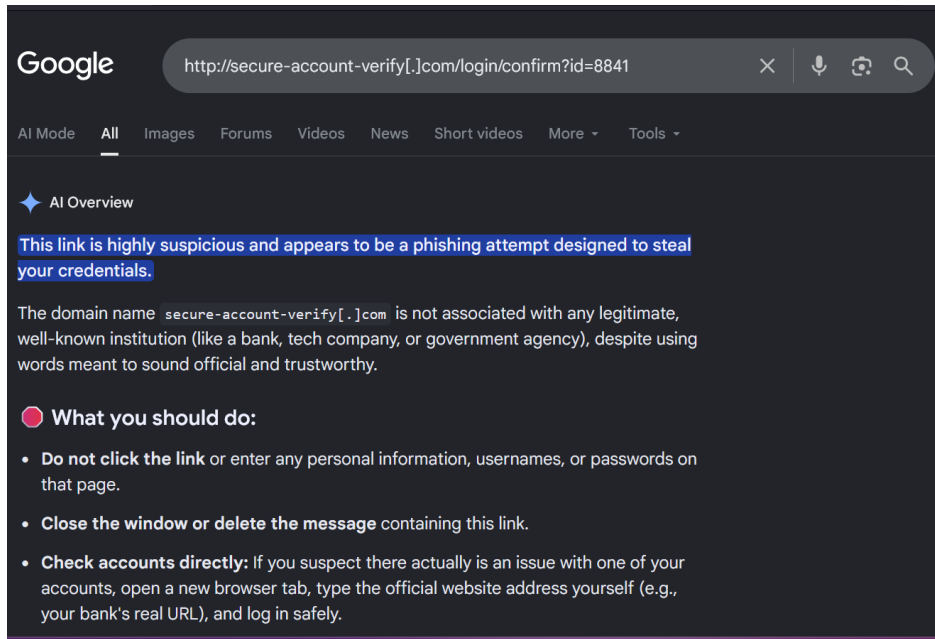


Figure 1: Google search for the link in Sample 1.

What this shows: A search for the link returns an automated summary describing it as a credential-theft style link with no connection to any known institution. This is supporting context only, since it is an automated summary rather than a primary source.

	
SuperTool MX Lookup Blacklists DMARC Diagnostics Email Health DNS Lookup Analyze Headers	
SuperTool Beta9	
secure-account-verify.com Whois Lookup	
whois:secure-account-verify.com Find Problems	
Name	Value
Registrar	Cloudflare, Inc.
Name Server	ANNA.NS.CLOUDFLARE.COM
Name Server	JOSH.NS.CLOUDFLARE.COM
Registrant Name	DATA REDACTED
Registrant Organization	DATA REDACTED
Registrant Phone	+1.4153197517
Name	Value
Domain Name	SECURE-ACCOUNT-VERIFY.COM
Registry Domain ID	2099387607_DOMAIN_COM-VRSN
Registrar WHOIS Server	whois.cloudflare.com
Registrar URL	http://www.cloudflare.com
Updated Date	2026-01-03T04:14:18Z
Creation Date	2017-02-21T15:34:07Z
Registry Expiry Date	2027-02-21T15:34:07Z
Registrar	Cloudflare, Inc.
Registrar IANA ID	1910
Registrar Abuse Contact Email	registrar-abuse@cloudflare.com
Registrar Abuse Contact Phone	+1.6503198930
Domain Status	clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server	ANNA.NS.CLOUDFLARE.COM
Name Server	JOSH.NS.CLOUDFLARE.COM
DNSSEC	unsigned
URL of the ICANN Whois Inaccuracy Complaint Form	https://www.icann.org/wicf/
Last update of whois database	2026-09-27T15:36:21Z
to	(1) allow, enable, or otherwise support the transmission of mass

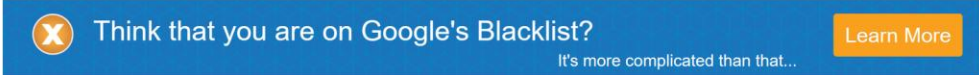
Figure 2: WHOIS lookup for secure-account-verify.com.

What this shows: The domain is registered (created February 2017) through Cloudflare, with registrant details redacted. Privacy redaction is common for legitimate owners too, so it is treated as neutral. What matters is that the name is not tied to any recognizable bank, tech company, or service.

SuperTool Beta9

[HTTP Lookup](#)

http:secure-account-verify.com/login/confirm?id=8841
[Monitor URL](#)



Server Type	Status	Content Type
cloudflare	522 timeout	text/plain; charset=UTF-8

Test	Result
HTTP Connect	The remote server returned an error: (522) timeout. (http:secure-account-verify.com/login/confirm?id=8841)

[More Info](#)

DNS Lookup
 Reported by metasploit.com on 9/27/2026 at 16:58:09 AM
 [Just fix you](#)

[DNS Lookup](#)
[Direct Lookup](#)
[Transcript](#)

Figure 3: HTTP lookup for the Sample 1 link.

What this shows: The server returned HTTP 522 (Cloudflare: origin not responding), so no live page was reachable at the time of testing. The sample link is therefore illustrative; no claim is made about the domain's owner.

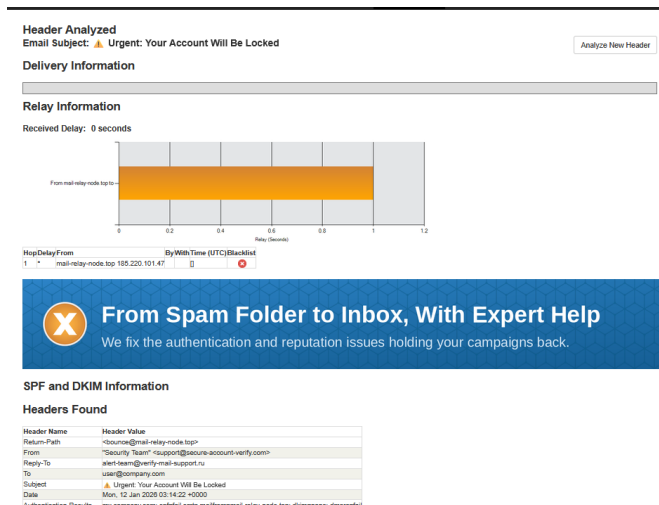


Figure 3b: Header analysis of Sample 1.

What this shows: Return-Path (mail-relay-node.top), From (secure-account-verify.com), and Reply-To (verify-mail-support.ru) are three unrelated domains. Authentication-Results reads spf=fail, dkim=none, dmarc=fail, and the relay IP (185.220.101.47) is flagged red in the blacklist column — unlike Sample 2 and Sample 4, where the relay showed a clean green check. This is independent, tool-verified evidence for the Phishing classification, separate from the domain-registration and HTTP checks above.

6.2 Sample 2 — Finance/Invoice

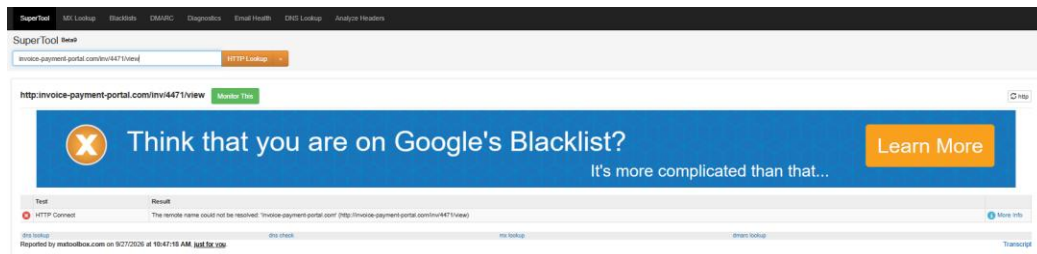


Figure 4: HTTP lookup for invoice-payment-portal.com.

What this shows: The lookup reports that the remote name could not be resolved, meaning this domain did not exist in DNS at the time of testing. A genuine vendor billing portal would always resolve.

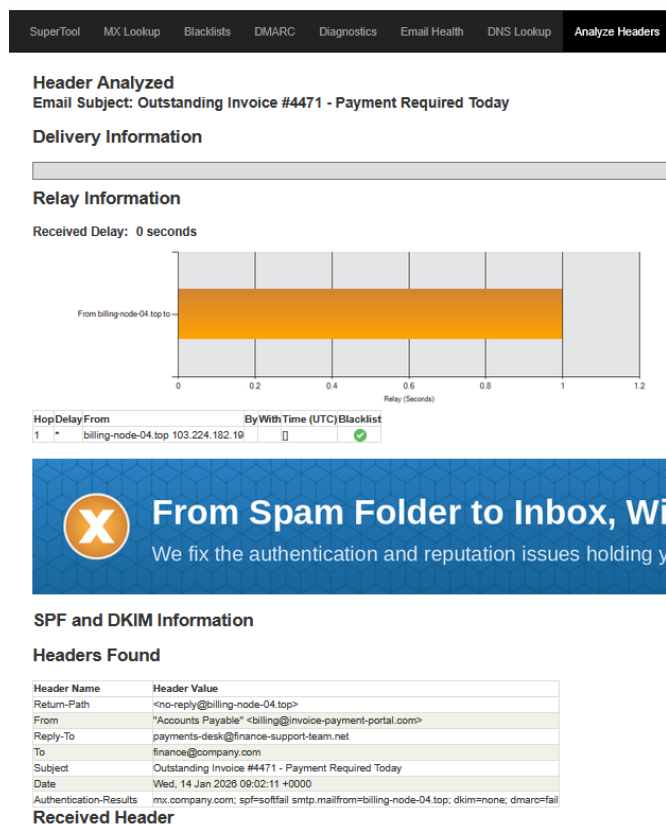


Figure 5: Header analysis of Sample 2.

What this shows: Three different domains appear across the header fields: Return-Path (billing-node-04.top), From (invoice-payment-portal.com), and Reply-To (finance-support-team.net). Legitimate senders keep these consistent. The Authentication-Results line reads spf=softfail, dkim=none, dmarc=fail, and the email came through a single relay on a .top domain. The green blacklist tick only means the relay IP is not on a blacklist, which does not make the email safe.

6.3 Sample 3 — IT Helpdesk Notice

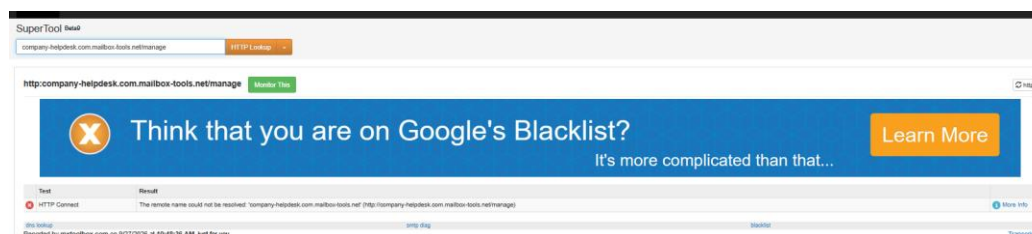


Figure 6: HTTP lookup for company-helpdesk.com.mailbox-tools.net/manage.

What this shows: This exact hostname could not be resolved. The key point is the structure of the link: in company-helpdesk.com.mailbox-tools.net, the real registrable domain is mailbox-tools.net, and the trusted-looking company-helpdesk.com is only a prefix. The parent domain mailbox-tools.net was not separately investigated, and no claim is made about it.

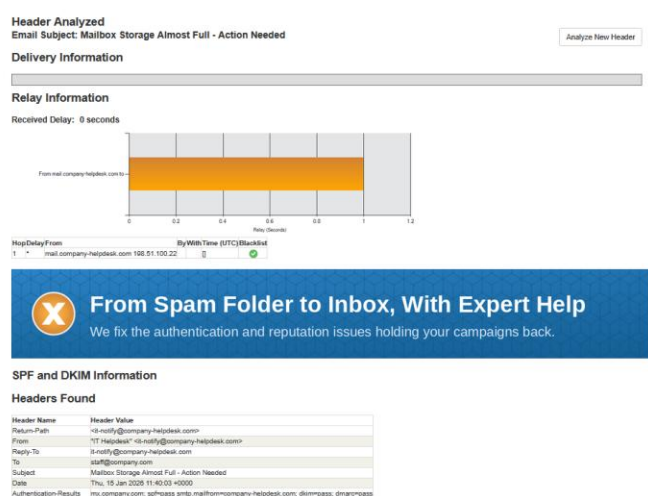


Figure 6b: Header analysis of Sample 3.

What this shows: Return-Path, From, and Reply-To are all consistent under company-helpdesk.com, the relay is not blacklisted, and Authentication-Results reads spf=pass, dkim=pass, dmarc=pass. This is the case referenced in the Risk Classification Framework: authentication passing for the sending domain says nothing about the mismatched link destination, which is the actual reason this sample is Suspicious rather than Safe.

6.4 Sample 4 — Legitimate Security Alert (baseline)

MX TOOLBOX
SUPERTOOL

SuperTool | MX Lookup | Blacklists | DMARC | Diagnostics | Email Health | DNS Lookup | Analyze Headers

SuperTool | Beta9

myaccount.google.com/notifications | HTTPS Lookup

https://myaccount.google.com/notifications | Monitor This

Think that you are on G

Certificate	
	Common Name: *.google.com - Issuer: WR2 - Expires: 2 months - Valid From: 9/10/2026 - Valid To: 12/3/2026 - Serial: 44BE00DE01AE960AB29255F94109E5 - Algorithm: sha256RSA
	Common Name: WR2 - Issuer: GTS Root R1 - Expires: 2 years - Valid From: 12/13/2023 - Valid To: 2/20/2029 - Serial: 7FF005A07C4CDED100AD0D6A5107B98 - Algorithm: sha256RSA - Organization: Google Trust Services - Location: US
	Common Name: GTS Root R1 - Issuer: GlobalSign Root CA - Expires: 1 year 4 months - Valid From: 9/18/2020 - Valid To: 1/27/2028 - Serial: 77B0D08CD838F91AEA210FC4F058D30D - Algorithm: sha256RSA - Organization: Google Trust Services LLC - Location: US
	Common Name: GlobalSign Root CA - Issuer: GlobalSign Root CA - Expires: 1 year 4 months - Valid From: 9/1/1998 - Valid To: 1/28/2028 - Serial: 040000000001154B5AC394 - Algorithm: sha1RSA - Organization: GlobalSign nv-sa - Location: BE

Figure 7: Certificate lookup for myaccount.google.com.

What this shows: The certificate is issued for *.google.com and chains through WR2 and GTS Root R1 to GlobalSign Root CA, all with valid dates. The name matches the domain in the email link exactly, which is what a legitimate destination looks like.

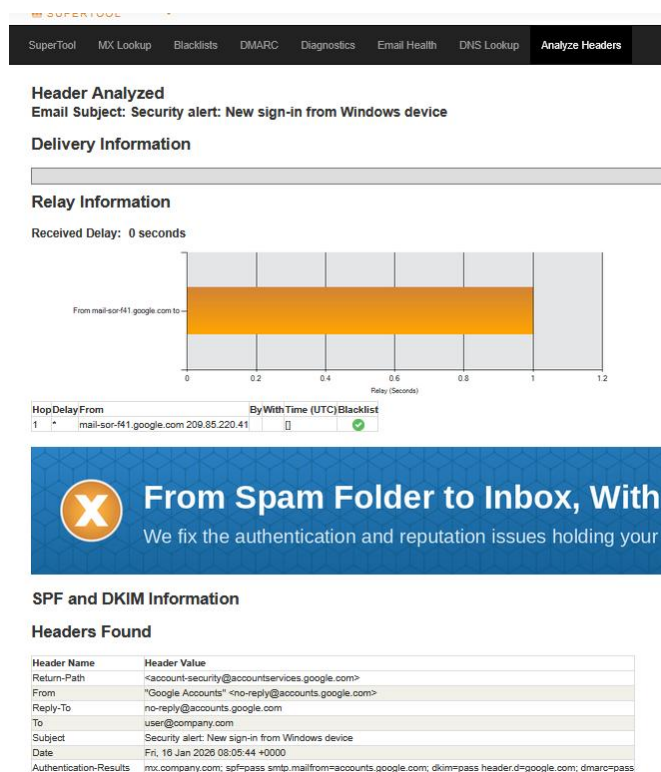


Figure 8: Header analysis of Sample 4.

What this shows: Return-Path, From, and Reply-To all sit under google.com, the email came through a single relay from a Google mail server, and the relay is not blacklisted. The Authentication-Results line reads spf=pass, dkim=pass, dmarc=pass. Everything is consistent, in contrast to Sample 2.

7. Common Phishing Indicators Checklist

- Sender domain does not match the organization it claims to represent.
- Reply-To or Return-Path differs from the visible From address.
- SPF, DKIM, or DMARC authentication fails.
- Urgent, threatening, or fear-based language (“account will be locked,” “act now”).
- Generic greetings instead of the recipient's real name.
- Links whose visible text hides a different underlying or lookalike domain.
- Unexpected requests for passwords, OTPs, payment details, or file downloads.
- Poor grammar, inconsistent formatting, or mismatched branding.

8. Prevention Guidelines

Do's

- Hover over links to check the real destination before clicking.
- Verify unexpected financial or account requests through a separate, known channel (phone call, official app).

- Report suspicious emails to IT/security rather than deleting them immediately.
- Check the full sender address, not just the display name.
- Enable multi-factor authentication wherever possible.

Don'ts

- Don't click links or download attachments from unexpected or urgent emails.
- Don't enter passwords or OTPs on a page reached via an email link.
- Don't reply to or forward suspicious emails to coworkers without flagging them as suspicious.
- Don't assume an email is safe just because it looks professionally formatted.
- Don't act purely because of a deadline or threat in the message — verify first.

9. Conclusion

Phishing succeeds by exploiting attention and trust, not just technical weaknesses. A consistent header-and-content review process — checking sender domain, authentication results, link destinations, and language patterns — catches the large majority of attempts, including the more convincing ones like Sample 3. Combining this analysis skill with simple employee habits (verify, don't rush, report) is the most cost-effective phishing defense available to most organizations.